Data privacy and security note: Udyam Digital

Scope. Synthetic-data prototype, designed as if handling real customer data under the DPDP Act, 2023.

Principle	What the design does
Notice and consent	Before any KYC data, a short summary and the full notice state what is collected, why, for how long and who sees it, in English or Hindi. Each purpose has its own unticked checkbox: KYC verification (required), order updates (optional). We store purpose, notice version, language and timestamp; customers can download a receipt.
Purpose limitation	KYC data is used only to verify the business and activate service. Order updates are a separate, optional consent.
Data minimisation	The advisor asks only for business facts. It never asks for Aadhaar, PAN or bank numbers. If volunteered, it is removed before the text is stored, logged or sent to the LLM, including spaced numbers and Indic digits, and the user is pointed to KYC. KYC asks only for what the order needs: a plan needing no GSTIN needs only ID and address proof.
Call-backs	Name and phone or email come only from a separate form with its own unticked consent, never from chat and never to the LLM. Requests are deleted after 90 days or when the customer removes them. They are stored in full for the team and masked on the demo queue.
Retention	Uploaded images are held in memory during verification and never written to disk. We keep only the verdict, reason, issue codes and masked fields. A GSTIN typed for lookup is never stored. **Proposed, to be confirmed with legal:** keep these for the life of the service. A job deletes KYC results with no order after 90 days and unpaid orders after 180.
Masking	ID and GSTIN values appear in the UI and database as last 4 characters only.
Withdrawal and rights	Consent can be withdrawn on the consent page or in the tracker, with or without an order. Withdrawing KYC consent deletes the stored KYC result; the consent record stays as proof, with a withdrawal timestamp. The Your Data page downloads everything we hold as JSON, takes correction requests, and erases on request (a paid order is kept for billing). Receipts come as text and as Kantara-format JSON. A breach runbook sets out who acts, and when.
Third parties	Document images and ID numbers never go to the LLM. Only redacted chat text does, after a notice in the chat, and owners can turn it off. KYC runs locally with Tesseract.
Voice	Optional, with its own unticked consent, because audio can't be redacted before it goes to Gemini. The notice asks owners not to speak ID numbers. The recording is held in memory and never stored. The transcript is redacted like typed text, and the owner checks it before sending.
Decision integrity	Code decides products, prices and verdicts. The LLM writes around slots that code fills with every number and product name, and never sees the owner's words when wording a plan. Other replies are checked, and anything unsupported is discarded.
Fair outcomes	An automated `rejected` needs hard evidence: an inactive registration or a number that contradicts the registry. Anything uncertain goes to `needs_review`, where one reviewer proposes and a different one confirms. File-tampering signals are shown to reviewers only and never change a verdict.
Secrets	The API key comes from an environment variable. `.env` and the database are gitignored.

Not production-ready. Before real use, this needs real authentication (each browser session is a user here), encryption at rest for SQLite, a tamper-proof audit log (a plain one exists now), a processor agreement with the LLM vendor, a real grievance officer (a placeholder address is shown now), and legal review of retention periods.

LLM provider. The prototype uses the free Gemini API tier, where the provider may use submitted text to improve its products. Only redacted chat text and, with consent, voice recordings are sent, and all data here is synthetic. Real customers would need a paid tier with a no-training commitment.